МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РФ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ БЮДЖЕТНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)
Факультет информационных технологий и компьютерной безопасности
Кафедра систем информационной безопасности

ОТЧЁТ
по научно-исследовательской работе студента

Тема: «Разработка интеллектуальной системы оценки и регулирования киберрисков инфраструктуры контейнеризации Kubernetes при компрометации контейнерных приложений»

Разработал студент
гр. КБ-211 «_____» К.Ю.Полыга
Подпись, дата Инициалы, фамилия

Руководитель: «_____»
Подпись, дата, должность, инициалы, фамилия

Защищен_____ Оценка_____
дата

Воронеж 2026

СОДЕРЖАНИЕ

ВВЕДЕНИЕ 3
1 Инфраструктура контейнеризации Kubernetes как объект защиты и анализ средств оценки её киберрисков 12
1.1 Инфраструктура контейнеризации в корпоративной автоматизированной информационной системе 12
1.1.1 Понятие контейнеризации и оркестрации контейнерных приложений 12
1.1.2 Компоненты кластера Kubernetes и границы доверия между ними 14
1.1.3 Статистика и тенденции инцидентов безопасности в контейнерных средах 16
1.2 Декомпозиция кластера на активы и границы доверия 18
1.3 Нормативное обеспечение защиты инфраструктуры контейнеризации 21
1.4 Недостатки конфигурации кластера как источник киберрисков 23
1.5 Информационное обеспечение риск-анализа контейнерных сред 26
1.5.1 Базы данных уязвимостей и угроз: CVE, NVD, банк данных угроз ФСТЭК России 26
1.5.2 Профили безопасности NIST SP 800-190 и CIS Kubernetes Benchmark 27
1.5.3 Матрица MITRE ATT&CK for Containers 28
1.6 Анализ существующих средств анализа защищённости контейнерных сред 30
1.7 Дерево угроз и индуцированных ими рисков инфраструктуры контейнеризации 32
1.8 Выводы по первому разделу 36
СПИСОК ЛИТЕРАТУРЫ 39

ВВЕДЕНИЕ

Переход корпоративных информационных систем к микросервисной архитектуре привёл к тому, что основной средой исполнения прикладного программного обеспечения стала инфраструктура контейнеризации, а система оркестрации Kubernetes – фактическим стандартом управления такой средой [1]. Кластер объединяет в едином контуре плоскость управления, вычислительные узлы, рабочие нагрузки и реестр образов контейнеров, каждый из которых обладает собственной границей доверия и собственным набором полномочий. Тем самым кластер определяет, какое приложение, к каким ресурсам инфраструктуры и в каком объёме прав допущено, а следовательно, задаёт границы того ущерба, который может быть нанесён организации при переходе контейнерного приложения под контроль нарушителя. Особенность рассматриваемого объекта состоит в том, что компрометация единственной рабочей нагрузки ею не ограничивается: избыточные полномочия сервисного аккаунта, примонтированный каталог узла или доступный сокет среды исполнения контейнеров превращают прикладной инцидент в компрометацию узла, а затем и плоскости управления, обесценивая прочие применённые средства защиты информации.

Распространённость рассматриваемого объекта защиты и характер наступающих в нём инцидентов подтверждаются данными зарубежных отраслевых исследований. По результатам ежегодного опроса State of Kubernetes Security Report доля организаций, отметивших не менее одного инцидента безопасности контейнерной среды в течение предшествовавших двенадцати месяцев, составила 93 % в 2022 году, 90 % в 2023 году, 89 % в 2024 году и 86 % в 2025 году, причём преобладающей причиной инцидента на всём протяжении наблюдения остаётся не уязвимость образа, а недостаток конфигурации: его доля изменялась в пределах от 45 до 53 % при доле инцидентов, вызванных уязвимостью программного обеспечения, от 27 до 33 % [2]. По данным исследования Cloud-Native Security and Usage Report доля учётных записей и сервисных аккаунтов кластеров, которым предоставлены полномочия, фактически не используемые рабочей нагрузкой, возросла с 84 % в 2022 году до 98 % в 2025 году, а доля рабочих нагрузок,

исполняемых с правами суперпользователя, составила порядка трети от общего их числа [3]. Согласно ежегодному исследованию Cloud Native Computing Foundation, оркестрация контейнерных приложений применяется в промышленной эксплуатации в 66 % организаций при общем уровне применения технологии 84–96 %, что определяет масштаб распространения объекта защиты [4]. Отчёт Data Breach Investigations Report фиксирует устойчивый рост доли инцидентов, в которых начальным вектором выступила эксплуатация уязвимости или недостатка конфигурации внешнего сервиса, с 14 % в 2023 году до 20 % в 2025 году [5].

Аналогичная тенденция наблюдается и в отечественной практике. По данным экспертно-аналитического центра InfoWatch число зарегистрированных утечек информации из российских организаций составило порядка 660 в 2023 году и превысило 1000 в 2024 году, при этом доля инцидентов, в которых нарушителем использовались штатные средства администрирования и предоставленные полномочия, а не вредоносное программное обеспечение, устойчиво возрастает [6]. Аналитические отчёты об актуальных киберугрозах показывают, что доля успешных атак на организации, приведших к нарушению основной деятельности, в 2024–2025 годах превысила треть от общего их числа, а среди применяемых нарушителем техник преобладают получение и использование действительных учётных данных и эксплуатация недостатков конфигурации внешних сервисов [7]. В банке данных угроз безопасности информации ФСТЭК России по состоянию на начало 2026 года зарегистрировано 222 угрозы безопасности информации, из которых к средам виртуализации и контейнеризации применимы 24 угрозы, включая угрозы выхода за пределы виртуальной машины, нарушения изоляции пользовательских данных и несанкционированного доступа к гипервизору и средствам управления средой виртуализации [8]. Отдельно следует отметить, что перечисленные угрозы описаны применительно к технологии виртуализации в целом и не содержат детализации по компонентам системы оркестрации контейнерных приложений.

Приведённые данные свидетельствуют о смене характера атаки на контейнерную инфраструктуру: нарушитель всё чаще не эксплуатирует

программный дефект в образе, а использует штатно предоставленные рабочей нагрузке полномочия и допущенные при развёртывании ослабления изоляции. Между тем действующий аппарат риск-анализа исторически построен вокруг уязвимостей программного обеспечения. Банк данных угроз безопасности информации ФСТЭК России [8], международные реестры CVE и NVD [9-10], а также средства количественной оценки – вектор CVSS версий 3.1 и 4.0 [11-12] и прогноз вероятности эксплуатации EPSS [13] – описывают дефект программного или аппаратного обеспечения и не предназначены для описания состояния конфигурации кластера. Привилегированный режим пода, монтирование узловых каталогов, избыточные привязки ролей механизма RBAC, неограниченный доступ к API-серверу и отсутствие политик допуска рабочих нагрузок не являются уязвимостями в принятом понимании, не получают идентификатора, не регистрируются ни в одном из перечисленных источников и по этой причине не попадают в расчёт меры риска, хотя именно они определяют вероятность успешной компрометации и величину её последствий.

Существующие средства анализа защищённости контейнерных сред – Kubescape и kube-bench [14-15], Trivy и Falco [16-17] – выполняют проверку объектов кластера на соответствие профилю безопасности, обнаруживают уязвимости образов и фиксируют аномальное поведение среды исполнения, однако устанавливают лишь факт наличия или отсутствия несоответствия, не переводя его в меру риска. Проверка носит пообъектный характер: каждый объект кластера оценивается изолированно, вследствие чего сочетаемость недостатков, образующих цепочку «выход за границы контейнера – компрометация узла – доступ к плоскости управления», остаётся вне рассмотрения. Между тем именно связность недостатков конфигурации определяет достижимость целевых активов кластера, а значит, и действительную величину риска, которая должна оцениваться в целом и переоцениваться непрерывно, по событиям изменения состава рабочих нагрузок, версий образов и политик доступа.

Степень проработанности темы. Вопросы риск-анализа в области защиты информации получили развитие в трудах отечественной научной школы, в которых

разработаны методики оценки рисков успешности реализации кибератак, построения риск-ландшафтов сетевых атак и организационно-правового обеспечения противодействия им [18-20]. Требования к защите информации в информационных системах установлены нормативными документами ФСТЭК России [21-23] и национальными стандартами [24-26]. Особенности обеспечения безопасности приложений, исполняемых в контейнерной среде, изложены в руководстве NIST SP 800-190 и наборе проверок CIS Kubernetes Benchmark [27-28], а техники, применяемые нарушителем в инфраструктуре контейнеризации, систематизированы в матрице MITRE ATT&CK for Containers [29]. Вместе с тем в известных работах объектом риск-анализа выступают программное обеспечение и информационная система в целом, а контейнерное приложение рассматривается как носитель уязвимостей, а не как начальное звено цепочки компрометации инфраструктуры. Не решённой остаётся задача количественного сопоставления рабочих нагрузок кластера по вероятности компрометации и величине наступающего ущерба, что и определяет горизонты настоящего исследования.

Актуальность темы исследования обусловлена наличием противоречий между:

- объективной необходимостью рассматривать кластер как связную систему активов с различными границами доверия – плоскостью управления, узлами, рабочими нагрузками и реестром образов – и сложившейся практикой оценки защищённости контейнерных сред по отдельным образам и их уязвимостям, при которой компрометация контейнерного приложения считается конечным событием, а не начальным звеном цепочки;

- потребностью в едином описании недостатков конфигурации кластера – привилегированных подов, монтирования узловых каталогов, избыточных привязок RBAC, неограниченного доступа к API-серверу – и ориентированностью баз данных уязвимостей – CVE, NVD, банка данных угроз ФСТЭК России – на дефекты программного кода, вследствие чего перечисленные недостатки не получают идентификатора и выпадают из риск-анализа;

- необходимостью количественного выражения критичности недостатков конфигурации кластера и инструментальной базой оценки критичности, представленной метриками CVSS версий 3.1 и 4.0 и прогнозной оценкой эксплуатации EPSS, которые построены для уязвимостей с присвоенным идентификатором и накопленной статистикой эксплуатации, отсутствующей у конфигурационных недостатков;

- необходимостью учёта сочетаемости недостатков, образующих цепочки «выход за границы контейнера – компрометация узла – доступ к плоскости управления», и пообъектным характером проверок средств анализа защищённости Kubescape, kube-bench, Trivy и Falco, оценивающих каждый объект кластера изолированно;

- потребностью в удержании оценки риска в актуальном состоянии при непрерывном изменении состава рабочих нагрузок, версий образов и политик доступа и статичностью действующих методик, предполагающих разовое обследование кластера по фиксированному профилю соответствия.

Объектом исследования является инфраструктура контейнеризации Kubernetes автоматизированной информационной системы организации, включающая плоскость управления, вычислительные узлы, рабочие нагрузки и реестр образов контейнеров.

Предметом исследования являются модели, методики и алгоритмы оценки и регулирования киберрисков, позволяющие количественно описывать вероятность компрометации контейнерных приложений и величину наступающего при этом ущерба, а также поддерживать полученные оценки в актуальном состоянии при изменении конфигурации кластера.

Целью исследования является повышение защищённости автоматизированных информационных систем за счёт разработки интеллектуальной системы оценки и регулирования киберрисков инфраструктуры контейнеризации Kubernetes в условиях компрометации контейнерных приложений.

Для достижения поставленной цели необходимо решить следующие задачи:

- выполнить декомпозицию инфраструктуры контейнеризации на активы и границы доверия и построить на её основе дерево угроз и индуцированных ими рисков, наступающих при компрометации контейнерных приложений;

- сформировать базу знаний соответствий недостатков конфигурации кластера и эксплуатирующих их техник на основе CIS Kubernetes Benchmark, NIST SP 800-190 и матрицы MITRE ATT&CK for Containers с привязкой каждой пары к наступающему ущербу;

- разработать методику количественной оценки вероятности успешной компрометации контейнерного приложения и наступающего ущерба на основе адаптации базовых, контекстных и средовых метрик CVSS 4.0 [12] к контексту кластера;

- сформировать типовые сценарии компрометации кластера в виде путей достижимости активов, размеченных техниками MITRE ATT&CK for Containers, с расчётом риска успешности каждого сценария и построить риск-ландшафт кластера;

- создать интеллектуальную систему оценки и регулирования киберрисков кластера, выполняющую классификацию рабочих нагрузок по уровню риска средствами машинного обучения и пересчёт риск-ландшафта при смене снимка конфигурации, и сформировать комплекс мер регулирования, классифицированных по масштабности и профильности.

Методы исследования. При решении поставленных задач применялись методы системного анализа и декомпозиции сложных систем, аппарат теории рисков, методы теории вероятностей и математической статистики, теория графов при построении дерева угроз и графа достижимости активов кластера, методы машинного обучения с учителем при классификации рабочих нагрузок по уровню риска, а также методы объектно-ориентированного программирования при разработке программного обеспечения интеллектуальной системы.

Решение поставленных задач позволило сформировать следующие результаты, выносимые на защиту:

- модель объекта защиты в виде декомпозиции кластера на активы и границы доверия и построенное на ней дерево угроз и индуцированных рисков;

- база знаний троек «недостаток конфигурации кластера – эксплуатирующая техника – наступающий ущерб», покрывающая все выделенные активы объекта защиты;

- методика и реализующий её алгоритм расчёта меры риска компрометации контейнерного приложения, определяемой как произведение вероятности наступления ущерба на его величину;

- множество сценариев компрометации, представленных путями в графе достижимости, и риск-ландшафт кластера, построенный по осям «актив кластера», «техника эксплуатации» и «мера риска»;

- программное обеспечение интеллектуальной системы с моделью классификации рабочих нагрузок по уровню риска и комплекс мер регулирования риск-ландшафта кластера с оценкой достигаемого снижения меры риска.

Новизна полученных результатов заключается в следующем:

- впервые дерево угроз построено для кластера как связной системы, в которой компрометация контейнерного приложения выступает начальным, а не конечным событием, что позволяет включить в рассмотрение переходы между границами доверия;

- впервые недостатки конфигурации Kubernetes, не обладающие идентификаторами уязвимостей, поставлены в однозначное соответствие техникам их эксплуатации и представлены в форме, пригодной для машинной обработки;

- впервые количественная оценка критичности получена для недостатков без идентификатора уязвимости за счёт переноса метрик на контекст кластера: уровень привилегий пода, пересекаемую границу доверия и доступность плоскости управления;

- впервые риск кластера определяется не суммой независимых несоответствий профилю, а достижимостью целевых активов по графу сценариев, что учитывает взаимное усиление недостатков конфигурации;

- впервые уровень риска рабочей нагрузки определяется обученной моделью по совокупности параметров её манифеста, а меры регулирования оцениваются величиной снижения меры риска, а не фактом соответствия профилю безопасности.

Практическая ценность полученных результатов состоит в следующем:

- применение модели объекта защиты позволяет специалисту очертить границы объекта защиты и получить перечень контролируемых узлов кластера при проектировании защиты контейнерной платформы;

- применение базы знаний позволяет получить готовый перечень проверяемых параметров кластера с указанием техники эксплуатации и ожидаемого ущерба без обращения к разрозненным источникам;

- применение методики позволяет оперативно вычислять параметры риска компрометации отдельной рабочей нагрузки и ранжировать нагрузки кластера по критичности;

- применение риск-ландшафта позволяет выявить сочетания недостатков с наибольшей мерой риска и сосредоточить защитные ресурсы на сценариях, ведущих к плоскости управления;

- применение разработанной системы снимает необходимость ручного аудита при каждом изменении кластера и даёт обоснование выбора мер защиты по критерию достигаемого снижения риска.

Теоретическая значимость результатов исследования определяется следующим образом:

- полученная декомпозиция может быть распространена на иные платформы оркестрации – OpenShift, Nomad – и служит основой для анализа защищённости сервисных сеток;

- полученное соответствие может быть расширено на шаблоны инфраструктуры как кода и политики допуска рабочих нагрузок, а также использовано для корреляционного анализа накопленных данных;

- полученный подход может быть распространён на иные классы объектов защиты, не обладающих идентификаторами уязвимостей;

- полученный граф достижимости может быть сужен до актуального множества сценариев либо расширен на мультикластерные и гибридные среды;

- полученное обеспечение может быть распространено на оптимизацию риск-ландшафта контейнерных сред различного назначения.

Апробация результатов. Результаты исследования планируются к докладу на научно-практических конференциях и семинарах, проводимых кафедрой систем информационной безопасности, а также к обсуждению в рамках научно-исследовательской работы обучающихся.

Публикация результатов. Результаты исследования планируются к опубликованию в научном журнале «Информация и безопасность», а также в сборниках трудов научно-практических конференций по направлению обеспечения информационной безопасности.

Настоящая работа выполнена в объёме научно-исследовательской работы и содержит введение, первый раздел выпускной квалификационной работы и список литературы. В первом разделе выполняется исследование инфраструктуры контейнеризации Kubernetes как объекта защиты: проводится декомпозиция кластера на активы и границы доверия, устанавливается соответствие нормативных требований параметрам конфигурации кластера, анализируются информационное обеспечение риск-анализа и существующие средства анализа защищённости контейнерных сред и строится дерево угроз и индуцированных ими рисков, наступающих при компрометации контейнерных приложений. Решение остальных поставленных задач составляет содержание последующих разделов выпускной квалификационной работы.

1 Инфраструктура контейнеризации Kubernetes как объект защиты и анализ средств оценки её киберрисков

Настоящий раздел посвящён обоснованию целеполагания и постановке задач исследования. В соответствии с методическими рекомендациями по выполнению работ в области обеспечения информационной безопасности [18] изложение строится от объекта защиты и присущих ему угроз через оценку индуцированных этими угрозами рисков к последующему риск-управлению. Исследование опирается на терминологию, принятую в отечественной научной школе [24], согласно которой безопасность есть состояние защищённости от внешних и внутренних угроз, при котором риск реализации этих угроз не превышает допустимых значений; угроза – совокупность факторов, воздействие которых способно привести к ущербу; ущерб – совокупность негативных последствий реализации угроз; риск – возможность наступления ущерба от реализации угроз, а мера риска определяется произведением величины ожидаемого ущерба на вероятность его наступления.

Задачами раздела являются построение модели инфраструктуры контейнеризации Kubernetes как объекта защиты, выполнение её декомпозиции на активы и границы доверия, установление соответствия между нормативными требованиями к защите информации и параметрами конфигурации кластера, классификация недостатков конфигурации, анализ информационного обеспечения риск-анализа контейнерных сред и существующих средств анализа защищённости, а также построение дерева угроз и индуцированных ими рисков, наступающих при компрометации контейнерных приложений.

1.1 Инфраструктура контейнеризации в корпоративной автоматизированной информационной системе

1.1.1 Понятие контейнеризации и оркестрации контейнерных приложений

Контейнеризация представляет собой разновидность виртуализации на уровне операционной системы, при которой прикладное программное обеспечение вместе с необходимыми ему библиотеками и зависимостями упаковывается в образ и

исполняется изолированно от прочих приложений, но в среде общего ядра операционной системы узла. Изоляция обеспечивается механизмами ядра – пространствами имён, разграничивающими видимость процессов, сетевых интерфейсов, точек монтирования и идентификаторов пользователей, и контрольными группами, ограничивающими потребление вычислительных ресурсов. Принципиальное отличие контейнеризации от виртуализации на основе гипервизора состоит в том, что контейнеры не располагают собственным ядром: граница изоляции между контейнером и узлом реализуется программно, средствами того же ядра, которое обслуживает все исполняемые на узле рабочие нагрузки. Вследствие этого ослабление параметров изоляции, допущенное при развёртывании, переводит инцидент прикладного уровня в инцидент уровня инфраструктуры, что и определяет специфику рассматриваемого объекта защиты [30].

Жизненный цикл контейнерного приложения включает сборку образа, его размещение в реестре образов, получение образа узлом и запуск контейнера средой исполнения. Каждый из перечисленных этапов образует самостоятельную точку приложения усилий нарушителя: образ может содержать внесённый в него посторонний код, реестр – выдать подменённый образ, среда исполнения – запустить контейнер с избыточными полномочиями. Тем самым защищённость исполняемого приложения определяется не только его собственным кодом, но и параметрами всей цепочки, по которой это приложение оказалось на узле.

По мере роста числа контейнерных приложений их ручное размещение становится неосуществимым, вследствие чего применяются системы оркестрации, принимающие на себя планирование размещения рабочих нагрузок по узлам, их масштабирование, организацию сетевого взаимодействия, предоставление хранилищ и управление конфиденциальными параметрами. Kubernetes является де-факто стандартом оркестрации контейнерных приложений [1] и применяется как в собственных центрах обработки данных организаций, так и в облачных средах. Существенно, что система оркестрации не только управляет рабочими нагрузками, но и сама выступает носителем полномочий: она располагает учётными данными для обращения к реестру образов, хранит конфиденциальные параметры

приложений и обладает возможностью запуска произвольной рабочей нагрузки на любом подчинённом узле. Компрометация системы оркестрации, таким образом, эквивалентна компрометации всех обслуживаемых ею приложений и данных.

1.1.2 Компоненты кластера Kubernetes и границы доверия между ними

Кластер Kubernetes образован двумя группами компонентов. Плоскость управления включает сервер программных интерфейсов kube-apiserver, являющийся единственной точкой обращения к кластеру и выполняющий аутентификацию, авторизацию и допуск запросов; распределённое хранилище etcd [31], содержащее полное состояние кластера, включая конфиденциальные параметры приложений; планировщик kube-scheduler, определяющий узел размещения рабочей нагрузки; и менеджер контроллеров kube-controller-manager, приводящий фактическое состояние кластера к заданному. Вычислительные узлы включают агент kubelet, управляющий жизненным циклом контейнеров на узле и обращающийся к серверу программных интерфейсов; сетевой агент kube-proxy; и среду исполнения контейнеров [32], непосредственно взаимодействующую с ядром операционной системы узла.

Рабочие нагрузки представлены подами – минимальными планируемыми единицами, объединяющими один или несколько контейнеров с общими пространствами имён. Каждому поду сопоставляется сервисный аккаунт, от имени которого выполняются обращения к серверу программных интерфейсов; объём предоставленных сервисному аккаунту прав определяется механизмом управления доступом на основе ролей [33]. Реестр образов, располагающийся вне кластера либо в его составе, хранит образы, из которых создаются контейнеры, и является точкой, определяющей доверие к исполняемому коду.

Перечисленные компоненты не равнозначны с точки зрения защиты информации: они располагают различным объёмом полномочий, обслуживают различные множества субъектов и влекут различный ущерб при компрометации. Соответствующее сопоставление приведено в таблице 1.

Таблица 1 – Компоненты кластера Kubernetes и последствия их компрометации

Компонент кластера	Назначение и располагаемые полномочия	Последствия компрометации
Сервер программных интерфейсов	Единственная точка обращения к кластеру; выполняет аутентификацию, авторизацию и допуск запросов	Полное управление кластером, запуск произвольных рабочих нагрузок на любом узле
Хранилище etcd	Хранит полное состояние кластера, включая конфиденциальные параметры приложений	Утрата конфиденциальности всех секретов кластера, возможность подмены его состояния
Планировщик и менеджер контроллеров	Определяют размещение рабочих нагрузок и приводят состояние кластера к заданному	Управление размещением нагрузок, размещение посторонней нагрузки на выбранном узле
Агент узла kubelet	Управляет жизненным циклом контейнеров на узле, обращается к серверу программных интерфейсов	Управление всеми контейнерами узла, доступ к их конфиденциальным параметрам
Среда исполнения контейнеров	Создаёт и исполняет контейнеры, взаимодействует с ядром операционной системы узла	Получение прав на узле, выход за границы изоляции контейнера
Рабочая нагрузка (под)	Исполняет прикладной код, располагает правами сопоставленного сервисного аккаунта	Исходная точка цепочки компрометации инфраструктуры
Реестр образов	Хранит образы, из которых создаются контейнеры	Внесение постороннего кода во все создаваемые из образа контейнеры

Между перечисленными компонентами устанавливаются границы доверия – условные рубежи, пересечение которых нарушителем означает расширение множества доступных ему активов и, как следствие, возрастание величины наступающего ущерба. В рассматриваемом объекте защиты выделяются четыре такие границы: между контейнером и узлом, на котором он исполняется; между узлом и плоскостью управления кластера; между пространствами имён, разграничивающими рабочие нагрузки различных подразделений или систем; между кластером и внешним реестром образов. Именно переходы между границами доверия, а не отдельные несоответствия профилю безопасности, определяют развитие компрометации, что и обусловливает принятый в настоящей работе подход к построению модели объекта защиты.

1.1.3 Статистика и тенденции инцидентов безопасности в контейнерных средах

Количественные характеристики инцидентов безопасности контейнерных сред приводятся в ежегодных отраслевых исследованиях, выполняемых по опросам эксплуатирующих организаций и по данным систем мониторинга. Сводные показатели за четыре года наблюдения приведены в таблице 2.

Таблица 2 – Динамика показателей безопасности контейнерных сред по данным зарубежных отраслевых исследований

Показатель	2022	2023	2024	2025	Источник
Доля организаций, отметивших не менее одного инцидента безопасности контейнерной среды за 12 месяцев, %	93	90	89	86	[2]
Доля инцидентов, вызванных недостатком конфигурации, %	53	45	46	48	[2]
Доля инцидентов, вызванных уязвимостью образа, %	27	33	32	30	[2]
Доля организаций, задержавших развёртывание приложений из-за выявленных проблем безопасности, %	55	67	42	46	[2]
Доля предоставленных, но не используемых полномочий сервисных аккаунтов, %	84	90	98	98	[3]
Доля организаций, применяющих оркестрацию в промышленной эксплуатации, %	60	63	66	66	[4]

Приведённые в таблице 2 данные обнаруживают три устойчивые тенденции. Во-первых, доля организаций, столкнувшихся с инцидентом безопасности контейнерной среды, на всём интервале наблюдения превышает четыре пятых, то есть инцидент в такой среде является не исключительным, а ожидаемым событием. Во-вторых, недостаток конфигурации устойчиво преобладает над уязвимостью образа в качестве причины инцидента, и соотношение между ними не изменяется в пользу уязвимостей при том, что средства выявления уязвимостей образов получили за рассматриваемый период наибольшее распространение. В-третьих, доля предоставленных, но не используемых полномочий сервисных аккаунтов

приближается к предельной, что означает систематическое превышение фактически необходимого объёма прав рабочих нагрузок и, как следствие, систематическое завышение величины ущерба, наступающего при компрометации отдельного контейнерного приложения.

Отечественная статистика подтверждает установленные тенденции применительно к российским организациям. Согласно данным экспертно-аналитического центра InfoWatch, число зарегистрированных утечек информации выросло с порядка 660 в 2023 году до величины, превышающей 1000 в 2024 году, при сохранении высокой доли инцидентов, в которых нарушитель действовал от имени легитимной учётной записи [6]. Аналитические отчёты об актуальных киберугрозах фиксируют, что более трети успешных атак на организации в 2024–2025 годах привели к нарушению основной деятельности, а в числе преобладающих техник указываются использование действительных учётных данных и эксплуатация недостатков конфигурации доступных из внешних сетей сервисов [7]. В банке данных угроз безопасности информации ФСТЭК России зарегистрировано 222 угрозы, из которых к средам виртуализации и контейнеризации применимы 24, в том числе угрозы выхода за пределы виртуальной машины, нарушения изоляции пользовательских данных и несанкционированного доступа к средствам управления средой виртуализации [8]. Перечисленные угрозы сформулированы для технологии виртуализации в целом и не детализированы по компонентам системы оркестрации, вследствие чего непосредственное их применение к кластеру Kubernetes требует дополнительного уточнения объектов воздействия, выполняемого в настоящей работе.

Приведённые данные позволяют заключить, что преобладающей причиной инцидентов в контейнерных средах выступает не дефект программного кода в образе приложения, а состояние конфигурации самой инфраструктуры – избыточные полномочия рабочих нагрузок, ослабленные параметры изоляции и недостаточное разграничение доступа к плоскости управления. Данное обстоятельство определяет выбор недостатков конфигурации кластера, а не

уязвимостей программного обеспечения, в качестве множества, подлежащего риск-анализу в настоящей работе.

1.2 Декомпозиция кластера на активы и границы доверия

Исходным этапом риск-анализа инфраструктуры контейнеризации является построение модели объекта защиты. До тех пор пока не установлен перечень образующих её активов и не определены рубежи между ними, не могут быть заданы ни множество угроз, ни величина наступающего при их реализации ущерба, вследствие чего дальнейшие построения лишаются предметной основы.

Декомпозиция выполняется сверху вниз: от кластера как целого к образующим его компонентам, рассмотренным в подразделе 1.1.2. Отнесение компонента к активам производится по двум признакам: компонент располагает собственным набором полномочий, отличным от полномочий смежных компонентов, и его компрометация влечёт ущерб, поддающийся определению. Компоненты, не удовлетворяющие обоим признакам, в модель не включаются, поскольку не образуют самостоятельных узлов в последующем дереве угроз. Границы доверия устанавливаются там, где объём полномочий изменяется скачкообразно, то есть переход нарушителя через такой рубеж расширяет множество доступных ему активов.

Построение модели объекта защиты выполняется путём декомпозиции кластера на активы – элементы инфраструктуры, обладающие самостоятельной ценностью и собственным набором полномочий, – и установления границ доверия между ними. Под активом в настоящей работе понимается элемент инфраструктуры контейнеризации, компрометация которого влечёт определимый ущерб и который может выступать как целью, так и промежуточным звеном действий нарушителя. Множество активов формируется по компонентам кластера, выделенным в подразделе 1.1.2, и объединяется в четыре группы: плоскость управления, вычислительные узлы, рабочие нагрузки и реестр образов. Модель объекта защиты приведена на рисунке 1.

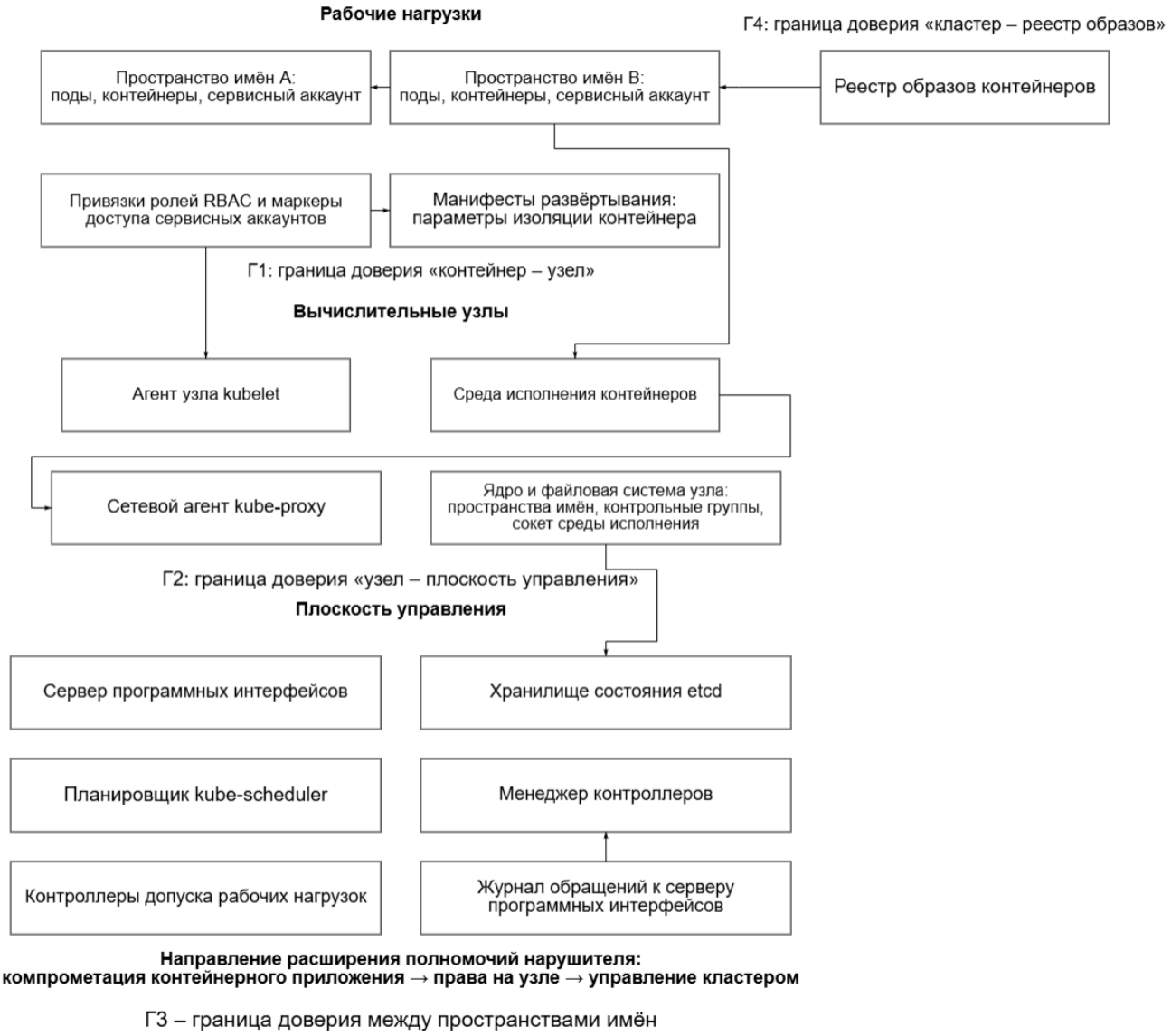


Рисунок 1 – Модель объекта защиты: декомпозиция кластера Kubernetes на активы и границы доверия

Предложенная декомпозиция обладает свойством полноты относительно принятой модели объекта защиты: каждому компоненту кластера, выделенному в таблице 1, соответствует ровно один актив, а всякий актив отнесён ровно к одной группе. Это отвечает требованию недопустимости фрагментарного и бессистемного рассмотрения проблемы [18] и обеспечивает возможность последующего расширения множества активов при появлении новых компонентов – например, подсистемы сервисной сетки или контроллеров допуска рабочих нагрузок.

Существенной особенностью построенной модели является положение рабочей нагрузки в структуре объекта защиты. В сложившейся практике оценки

защищённости контейнерных сред контейнерное приложение рассматривается как конечная цель нарушителя: обнаружение уязвимости в образе фиксируется как самостоятельный результат, а последствия ограничиваются нарушением свойств безопасности самого приложения. В настоящей работе рабочая нагрузка принимается в качестве начального звена цепочки: компрометация контейнерного приложения рассматривается как исходное событие, от которого при наличии соответствующих недостатков конфигурации становятся достижимыми узел, плоскость управления и, как следствие, все обслуживаемые кластером приложения и данные. Такое смещение исходного события позволяет включить в рассмотрение переходы между границами доверия, остающиеся вне поля зрения при пообъектной оценке.

Из принятой модели следует, что величина ущерба от компрометации отдельной рабочей нагрузки определяется не свойствами самой нагрузки, а множеством активов, достижимых при её использовании. Две рабочие нагрузки, исполняющие идентичный прикладной код, влекут различный ущерб при компрометации, если одна из них исполняется в привилегированном режиме с примонтированным каталогом узла, а вторая – с минимальным набором полномочий и ограниченным доступом к серверу программных интерфейсов. Данное положение определяет требование к разрабатываемому методическому обеспечению: единицей риск-анализа должна выступать рабочая нагрузка кластера, а не образ контейнера или обнаруженная в нём уязвимость.

1.3 Нормативное обеспечение защиты инфраструктуры контейнеризации

Требования к защите информации, обрабатываемой в автоматизированных информационных системах, частью которых выступает инфраструктура контейнеризации, установлены нормативными правовыми актами и методическими документами ФСТЭК России, а также национальными стандартами. Приказ ФСТЭК России № 17 определяет состав мер защиты информации в государственных информационных системах, приказ № 21 – в информационных системах персональных данных, приказ № 239 – на значимых объектах критической информационной инфраструктуры [21-23]. Порядок определения угроз безопасности информации установлен методическим документом «Методика оценки угроз безопасности информации» [34], в соответствии с которым угроза описывается совокупностью нарушителя, способа реализации, объекта воздействия и наступающих последствий.

Особенности защиты информации при использовании технологий виртуализации установлены ГОСТ Р 56938-2016 [35], который вводит перечень мер защиты, применяемых к средствам виртуализации, включая разграничение доступа к средствам управления виртуальной инфраструктурой, контроль целостности образов, регистрацию событий безопасности и изоляцию вычислительных ресурсов. Классификация и правила описания уязвимостей информационных систем установлены ГОСТ Р 56545-2015 и ГОСТ Р 56546-2015 [25-26], причём последний относит к самостоятельному классу уязвимости конфигурации, возникающие в результате задания параметров программного обеспечения, обеспечивающих возможность реализации угроз. Общие положения менеджмента риска информационной безопасности установлены ГОСТ Р ИСО/МЭК 27005-2010, ГОСТ Р ИСО 31000-2019 и ГОСТ Р 58771-2019 [36-37], определяющими риск через сочетание вероятности события и его последствий и устанавливающими перечень применимых технологий оценки риска.

Существенно, что перечисленные документы формулируют требования к защите информации в терминах мер защиты и не содержат указаний на конкретные параметры конфигурации системы оркестрации контейнерных приложений.

Соответствие между требуемыми мерами защиты и параметрами кластера, посредством которых эти меры реализуются, устанавливается в настоящей работе и приведено в таблице 3.

Таблица 3 – Соответствие мер защиты информации и параметров конфигурации кластера

Мера защиты информации и её источник	Параметр конфигурации кластера, реализующий меру	Последствие неприменения меры
Идентификация и аутентификация субъектов доступа (приказ ФСТЭК России № 17, ИАФ) [21]	Запрет анонимных обращений к серверу программных интерфейсов и к агенту узла kubelet	Доступ к объектам кластера без прохождения аутентификации
Управление доступом субъектов к объектам (приказ ФСТЭК России № 17, УПД) [21]	Привязки ролей механизма RBAC, ограниченные необходимым объёмом полномочий	Обращение рабочей нагрузки к объектам кластера за пределами прикладной задачи
Регистрация событий безопасности (приказ ФСТЭК России № 17, РСБ) [21]	Политика журналирования обращений к серверу программных интерфейсов, ретенция журналов	Невозможность установления обстоятельств инцидента
Защита среды виртуализации (ГОСТ Р 56938-2016) [35]	Запрет привилегированного режима пода, монтирования каталогов узла и пространств имён узла	Переход нарушителя с уровня контейнера на уровень узла
Обеспечение целостности информационной системы (приказ ФСТЭК России № 17, ОЦЛ) [21]	Проверка подписи образа, перечень допустимых реестров, неизменяемые идентификаторы содержимого	Исполнение постороннего кода, внесённого в образ контейнера
Защита информации при её передаче (ГОСТ Р 56938-2016) [35]	Взаимная аутентификация компонентов плоскости управления, шифрование хранимых секретов	Раскрытие конфиденциальных параметров кластера
Управление конфигурацией информационной системы (приказ ФСТЭК России № 17, УКФ) [21]	Политики допуска рабочих нагрузок, контроль изменений манифестов развёртывания	Развёртывание рабочей нагрузки с параметрами, не отвечающими требованиям защиты

Приведённое соответствие обнаруживает существенное для настоящей работы обстоятельство: всякая мера защиты информации, установленная нормативными документами применительно к инфраструктуре контейнеризации, реализуется значением одного или нескольких параметров конфигурации кластера, а неприменение меры выражается не в наличии уязвимости программного обеспечения, а в состоянии этих параметров. Тем самым нормативные требования

определяют множество контролируемых параметров, но не устанавливают порядка количественного сопоставления рабочих нагрузок между собой по величине наступающего риска, что и определяет необходимость разработки собственного методического обеспечения.

1.4 Недостатки конфигурации кластера как источник киберрисков

Под недостатком конфигурации кластера в настоящей работе понимается такое штатно установленное состояние параметров рабочей нагрузки, узла, плоскости управления или реестра образов, которое повышает вероятность успешной компрометации контейнерного приложения либо величину наступающего при этом ущерба, не являясь при этом уязвимостью программного обеспечения; в классификации уязвимостей информационных систем такие состояния относятся к самостоятельному классу уязвимостей конфигурации [26]. Принципиальным свойством недостатка конфигурации является его легитимность: привилегированный режим пода, монтирование каталога узла или расширенный набор привязок ролей представляют собой предусмотренные возможности платформы, применяемые при решении прикладных задач, и не могут быть устранены выпуском обновления. Классификация недостатков конфигурации, построенная по активам объекта защиты, приведена на рисунке 2.

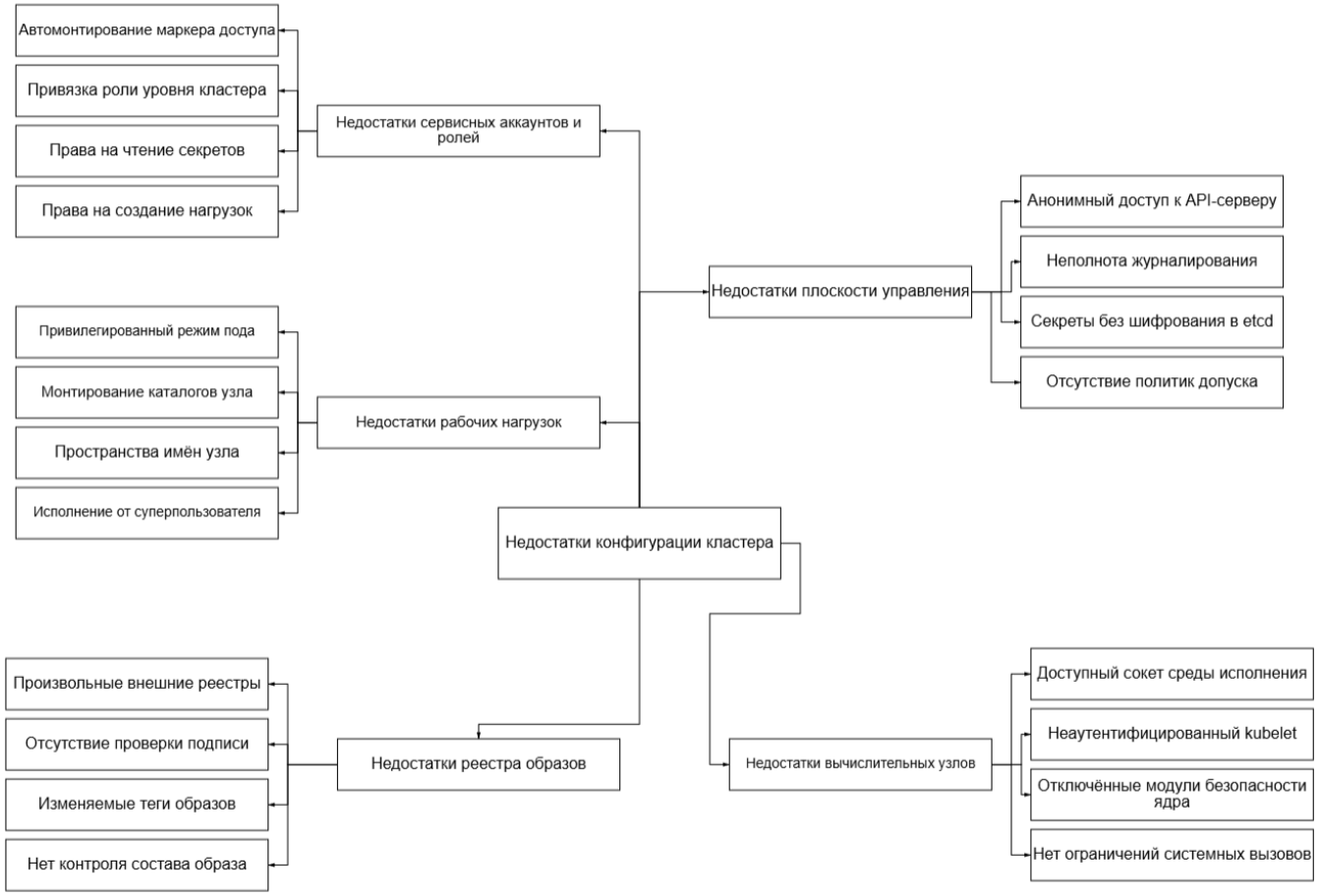


Рисунок 2 – Классификация недостатков конфигурации кластера по активам объекта защиты

Группа недостатков рабочих нагрузок объединяет параметры, ослабляющие изоляцию контейнера от узла и отнесённые стандартами безопасности рабочих нагрузок к недопустимым в ограничительном профиле [38]: запуск пода в привилегированном режиме; монтирование каталогов узла в файловую систему контейнера; использование пространств имён узла – сетевого, процессов и межпроцессного взаимодействия; предоставление контейнеру дополнительных возможностей ядра; исполнение процесса контейнера от имени суперпользователя; отсутствие запрета на повышение привилегий; доступная на запись корневая файловая система; отсутствие ограничений на потребление вычислительных ресурсов.

Группа недостатков сервисных аккаунтов и привязок ролей объединяет параметры, определяющие объём полномочий рабочей нагрузки в кластере:

автоматическое монтирование маркера доступа сервисного аккаунта в поды, которым обращение к серверу программных интерфейсов не требуется; привязка роли с полномочиями уровня кластера к сервисному аккаунту прикладной нагрузки; предоставление прав на чтение конфиденциальных параметров в пределах пространства имён; предоставление прав на создание рабочих нагрузок, эквивалентных по последствиям правам администратора узла.

Группа недостатков плоскости управления объединяет параметры доступа к управляющим компонентам: допуск анонимных обращений к серверу программных интерфейсов; отсутствие или неполнота настроек журналирования обращений; отсутствие шифрования конфиденциальных параметров при хранении; доступность хранилища etcd без взаимной аутентификации сторон; отсутствие политик допуска, ограничивающих параметры создаваемых рабочих нагрузок [39].

Группа недостатков вычислительных узлов объединяет параметры операционной системы и среды исполнения: доступность сокета среды исполнения контейнеров из рабочей нагрузки; допуск неаутентифицированных обращений к агенту узла; отсутствие принудительного разграничения доступа средствами модулей безопасности ядра; отсутствие ограничений на перечень системных вызовов, доступных контейнеру.

Группа недостатков реестра образов объединяет параметры доверия к исполняемому коду: получение образов из внешних источников без ограничения перечня допустимых реестров; отсутствие проверки подписи образа перед его запуском; использование изменяемых тегов образов вместо неизменяемых идентификаторов содержимого; отсутствие контроля состава образа.

Общим свойством перечисленных недостатков является отсутствие у них идентификатора уязвимости. Эмпирические исследования манифестов рабочих нагрузок, размещённых в открытых репозиториях, показывают, что перечисленные состояния параметров встречаются в значительной доле развёртываний и воспроизводятся при копировании типовых шаблонов [40]. Ни один из них не регистрируется в международных реестрах CVE и NVD, не включается в банк данных угроз безопасности информации ФСТЭК России в качестве уязвимости и не

принимается на вход калькуляторами критичности, построенными для уязвимостей с присвоенным идентификатором. Вследствие этого недостатки конфигурации кластера выпадают из риск-анализа, выполняемого по сложившейся методике, хотя именно они определяют достижимость активов кластера и, следовательно, действительную величину риска.

1.5 Информационное обеспечение риск-анализа контейнерных сред

1.5.1 Базы данных уязвимостей и угроз: CVE, NVD, банк данных угроз ФСТЭК России

Международный реестр CVE [9] обеспечивает присвоение уникальных идентификаторов общеизвестным уязвимостям программного и аппаратного обеспечения, а национальная база данных уязвимостей NVD [10] дополняет записи реестра сведениями о характеристиках уязвимости, включая вектор и базовую оценку критичности. Банк данных угроз безопасности информации ФСТЭК России содержит сведения об уязвимостях программного обеспечения, применяемого в информационных системах Российской Федерации, и перечень угроз безопасности информации, соотнесённых с объектами воздействия и последствиями их реализации [8].

Областью определения перечисленных источников является дефект программного или аппаратного обеспечения. Запись реестра уязвимостей соотносится с конкретной версией конкретного программного продукта и устраняется выпуском обновления либо применением компенсирующей меры. Недостаток конфигурации кластера такими свойствами не обладает: он не соотносится с версией программного обеспечения и не описывается типом недостатка программного обеспечения в принятых каталогах [41], не устраняется обновлением и представляет собой результат решения, принятого при развёртывании рабочей нагрузки. Как следствие, применение реестров уязвимостей к рассматриваемому множеству недостатков невозможно не вследствие неполноты этих реестров, а вследствие несовпадения областей определения.

Отдельно следует отметить средства количественной оценки критичности – вектор CVSS версий 3.1 и 4.0 [11-12] и прогнозную оценку вероятности эксплуатации EPSS [13]. Обе системы принимают на вход уязвимость с присвоенным идентификатором: первая исходит из характеристик самой уязвимости, вторая – из накопленной статистики наблюдаемых попыток эксплуатации. Для недостатков конфигурации кластера идентификатор отсутствует, а статистика эксплуатации не накапливается, вследствие чего непосредственное применение указанных средств неосуществимо. Подробное сопоставление калькуляторов критичности и обоснование выбранного способа переноса их метрик на контекст кластера выполняются в рамках выпускной квалификационной работы.

1.5.2 Профили безопасности NIST SP 800-190 и CIS Kubernetes Benchmark

Руководство NIST SP 800-190 по безопасности контейнерных приложений систематизирует риски контейнерной среды по пяти группам, соответствующим элементам её жизненного цикла: риски образов, риски реестров, риски систем оркестрации, риски контейнеров и риски операционной системы узла [27]. Для каждой группы приводятся характерные недостатки и рекомендуемые контрмеры. Существенно, что руководство описывает риски качественно: оно перечисляет, какие обстоятельства нежелательны и почему, но не вводит порядка количественного сопоставления рабочих нагрузок между собой.

Набор проверок CIS Kubernetes Benchmark представляет собой перечень контролируемых параметров кластера, сгруппированных по компонентам плоскости управления, хранилищу etcd, настройкам плоскости управления, вычислительным узлам и политикам [28]. Каждая проверка формулируется как требование к значению параметра и сопровождается порядком его установления и исправления. Сходные по составу перечни контролируемых параметров приводятся в наборе проверок среды исполнения контейнеров [42], в руководстве по усилению защищённости кластера [43] и в перечне наиболее значимых рисков инфраструктуры Kubernetes [44]. Результатом применения набора проверок является дискретная оценка соответствия: параметр либо удовлетворяет требованию, либо

нет. Перевод полученной оценки в меру риска набором проверок не предусмотрен, равно как не предусмотрен и учёт совместного влияния нескольких несоответствий.

Тем самым оба источника обеспечивают полноту перечня недостатков конфигурации, но не обеспечивают их количественного сопоставления. Именно это обстоятельство определяет их роль в настоящей работе: они принимаются в качестве источника множества недостатков, подлежащих учёту, тогда как порядок присвоения этим недостаткам количественных оценок разрабатывается самостоятельно.

1.5.3 Матрица MITRE ATT&CK for Containers

Матрица MITRE ATT&CK for Containers систематизирует техники, применяемые нарушителем в контейнерной инфраструктуре, распределяя их по тактикам – целям, преследуемым нарушителем на соответствующем этапе [29]. В отличие от реестров уязвимостей, матрица описывает не дефект, а способ действия, вследствие чего она применима к недостаткам конфигурации: техника соотносится с тем состоянием инфраструктуры, которое делает её осуществимой. Перечень техник, эксплуатирующих выделенные недостатки конфигурации кластера, приведён в таблице 4.

Таблица 4 – Техники матрицы MITRE ATT&CK for Containers, эксплуатирующие недостатки конфигурации кластера

Идентификатор	Наименование техники	Тактика	Эксплуатируемый недостаток конфигурации
T1610	Deploy Container	Execution, Defense Evasion	Права сервисного аккаунта на создание рабочих нагрузок
T1611	Escape to Host	Privilege Escalation	Привилегированный режим пода, монтирование каталогов узла
T1609	Container Administration Command	Execution	Доступность сокета среды исполнения из рабочей нагрузки
T1613	Container and Resource Discovery	Discovery	Права сервисного аккаунта на чтение объектов кластера
T1552.007	Unsecured Credentials: Container API	Credential Access	Автоматическое монтирование маркера доступа сервисного аккаунта
T1525	Implant Internal Image	Persistence	Отсутствие проверки подписи образа, изменяемые теги
T1612	Build Image on Host	Defense Evasion	Доступность среды исполнения узла из рабочей нагрузки
T1496	Resource Hijacking	Impact	Отсутствие ограничений на потребление ресурсов
T1078	Valid Accounts	Persistence, Privilege Escalation	Избыточные привязки ролей, неотозванные полномочия

Приведённое сопоставление показывает, что всякому выделенному недостатку конфигурации соответствует наблюдаемая техника его эксплуатации, а всякой технике – определимое последствие. Это обстоятельство позволяет принять пару «недостаток конфигурации – техника эксплуатации» в качестве элементарной единицы описания и положить её в основание базы знаний, что согласуется с принятым в отечественной научной школе подходом к формализации знаний и данных о кибератаках и уязвимостях [45], формирование которой составляет содержание дальнейшего исследования.

Сопоставление рассмотренных источников информационного обеспечения риск-анализа приведено в таблице 5.

Таблица 5 – Сопоставление источников информационного обеспечения риск-анализа контейнерных сред

Источник	Что описывает	Применимость к недостаткам конфигурации кластера
CVE, NVD	Дефекты программного обеспечения с присвоенным идентификатором	Неприменим: недостаток конфигурации идентификатора не получает
Банк данных угроз ФСТЭК России	Уязвимости применяемого программного обеспечения и перечень угроз	Применим частично: угрозы соотносятся с объектами воздействия, уязвимости – нет
NIST SP 800-190	Риски контейнерной среды по элементам жизненного цикла	Применим как источник перечня недостатков; количественной оценки не даёт
CIS Kubernetes Benchmark	Контролируемые параметры кластера и требования к их значениям	Применим как источник перечня проверок; даёт дискретную оценку соответствия
MITRE ATT&CK for Containers	Техники действий нарушителя в контейнерной инфраструктуре	Применим: техника соотносится с состоянием конфигурации, делающим её осуществимой
CVSS 3.1, CVSS 4.0, EPSS	Количественные оценки критичности уязвимостей	Непосредственно неприменим: требует идентификатора и статистики эксплуатации

1.6 Анализ существующих средств анализа защищённости контейнерных сред

Практическая оценка защищённости контейнерных сред выполняется специализированными средствами, реализующими проверку объектов кластера на соответствие профилю безопасности, анализ состава образов и контроль поведения среды исполнения [14-15], [16-17]. Результаты сравнительного анализа наиболее распространённых средств приведены в таблице 6.

Таблица 6 – Сравнительный анализ средств анализа защищённости контейнерных сред

Средство	Что обеспечивает	Чего не обеспечивает
kube-bench	Проверку параметров кластера на соответствие набору CIS Kubernetes Benchmark	Не переводит несоответствие в меру риска, не учитывает связность недостатков
Kubescape	Проверку объектов кластера по нескольким профилям, сопоставление с техниками матрицы ATT&CK	Оценивает каждый объект изолированно, не вычисляет достижимость активов
Trivy	Выявление уязвимостей образов и ошибок в манифестах рабочих нагрузок	Ограничен уязвимостями с идентификаторами; ущерб от компрометации не оценивает
Falco	Обнаружение аномального поведения среды исполнения по правилам	Фиксирует отдельное событие, не связывая его с мерой риска рабочей нагрузки

Выполненный анализ позволяет установить четыре обстоятельства, общих для всех рассмотренных средств. Во-первых, результатом их работы является дискретная оценка соответствия – перечень выявленных несоответствий профилю безопасности либо перечень обнаруженных уязвимостей, – но не мера риска, определяемая произведением ущерба на вероятность его наступления. Во-вторых, проверка носит пообъектный характер: каждый объект кластера оценивается изолированно, вследствие чего сочетаемость недостатков, образующих цепочку перехода между границами доверия, остаётся вне рассмотрения. В-третьих, недостатки конфигурации, не обладающие идентификаторами уязвимостей, не получают количественной оценки критичности и приводятся в отчётах с качественными пометками, не допускающими сопоставления рабочих нагрузок между собой. В-четвёртых, обследование выполняется разово либо по расписанию и не предусматривает переоценки состояния при изменении состава рабочих нагрузок, версий образов и политик доступа, вследствие чего полученные результаты устаревают вместе с изменением конфигурации кластера.

Перечисленные обстоятельства образуют содержание противоречий, положенных в основу настоящего исследования, и определяют состав разрабатываемого методического, алгоритмического и программного обеспечения.

1.7 Дерево угроз и индуцированных ими рисков инфраструктуры контейнеризации

Выделенные недостатки конфигурации порождают системообразующую угрозу безопасности информации – компрометацию контейнерных приложений инфраструктуры контейнеризации, – которая индуцирует множество рисков, различающихся характером наступающих последствий. Дерево угрозы и индуцированных ею рисков, построенное для инфраструктуры контейнеризации Kubernetes, приведено на рисунке 3.



Рисунок 3 – Дерево угрозы и индуцированных ею рисков инфраструктуры контейнеризации Kubernetes

Индуцированные риски разделены на четыре группы по характеру последствий, наступающих для организации, эксплуатирующей кластер:

технические, информационные, экономические и правовые. Такое разделение позволяет соотнести каждый риск как с техническим состоянием объекта защиты, так и с величиной ущерба, подлежащей оценке при расчёте меры риска.

Технические риски отражают утрату контроля над элементами инфраструктуры: риск выхода за границы контейнера на вычислительный узел, наступающий при ослабленных параметрах изоляции рабочей нагрузки; риск захвата управления кластером, наступающий при обращении к серверу программных интерфейсов с полномочиями, превышающими необходимые; риск отказа в обслуживании рабочих нагрузок, наступающий при отсутствии ограничений на потребление вычислительных ресурсов узла.

Информационные риски отражают нарушение свойств безопасности обрабатываемой информации: риск утечки конфиденциальных параметров кластера, хранимых в его состоянии; риск компрометации маркеров доступа сервисных аккаунтов, предоставляющих права обращения к плоскости управления; риск подмены образов контейнеров, влекущий исполнение постороннего кода во всех создаваемых из образа рабочих нагрузках.

Экономические риски отражают имущественные потери организации: риск простоя обслуживаемых кластером сервисов; риск затрат на восстановление инфраструктуры и расследование инцидента; риск нецелевого расходования вычислительных ресурсов, характерный для контейнерных сред вследствие возможности скрытого запуска посторонних рабочих нагрузок.

Правовые риски отражают последствия невыполнения установленных требований: риск нарушения требований о защите персональных данных; риск нарушения требований по защите значимых объектов критической информационной инфраструктуры; риск применения санкций регулятора и предъявления судебных исков.

Реализация системообразующей угрозы проходит четыре последовательных этапа, соответствующих пересекаемым нарушителем границам доверия; каждому этапу отвечает частная угроза, индуцирующая собственную цепочку рисков:

- угроза У1 – выход за границы контейнера – реализуется техниками тактики повышения привилегий и индуцирует цепочку рисков: Р1.1 – получение прав на узле через рабочую нагрузку, исполняемую в привилегированном режиме; Р1.2 – доступ к файловой системе узла через примонтированный каталог; Р1.3 – управление контейнерами узла через доступный сокет среды исполнения;

- угроза У2 – компрометация вычислительного узла и перемещение внутри кластера – индуцирует цепочку рисков: Р2.1 – извлечение конфиденциальных параметров иных рабочих нагрузок, размещённых на том же узле; Р2.2 – доступ к сетевому окружению узла при использовании сетевого пространства имён узла; Р2.3 – размещение посторонней рабочей нагрузки при отсутствии политик допуска;

- угроза У3 – компрометация плоскости управления – индуцирует цепочку рисков: Р3.1 – обращение к серверу программных интерфейсов с полномочиями сервисного аккаунта, превышающими необходимые; Р3.2 – чтение конфиденциальных параметров кластера; Р3.3 – доступ к содержимому хранилища etcd, эквивалентный получению полного состояния кластера;

- угроза У4 – нарушение доступности и сокрытие следов – индуцирует цепочку рисков: Р4.1 – исчерпание вычислительных ресурсов узла при отсутствии ограничений на их потребление; Р4.2 – невозможность расследования инцидента при неполноте журналирования обращений к серверу программных интерфейсов; Р4.3 – сохранение присутствия нарушителя через подменённый образ в реестре.

Построенное дерево допускает формальное описание. Его вершинами нижнего уровня служат недостатки конфигурации, выделенные на рисунке 2, вершиной промежуточного уровня – индуцируемая ими угроза компрометации контейнерного приложения, вершинами верхнего уровня – технические, информационные, экономические и правовые риски; дуга между вершинами означает, что реализация нижележащего события создаёт возможность наступления вышележащего. Представление множества достижимых состояний системы графом и анализ путей нарушителя по нему развивают известные подходы к построению и анализу графов атак [46-47], в том числе вероятностные [48]. Путь от недостатка конфигурации к риску верхнего уровня образует сценарий компрометации, которому соответствует

последовательность техник матрицы ATT&CK for Containers. Мера риска отдельного сценария, в соответствии с принятым определением, есть произведение величины ущерба, наступающего при его реализации, на вероятность его реализации, а мера риска рабочей нагрузки определяется совокупностью реализуемых для неё сценариев. Существенно, что сценарии не являются несовместными: одна и та же рабочая нагрузка может быть скомпрометирована несколькими способами, а достигаемый при этом ущерб для разных сценариев частично совпадает, вследствие чего простое суммирование мер риска приводит к завышенной оценке. Порядок агрегирования, устраняющий это завышение, устанавливается при решении последующих задач исследования.

Построенное дерево согласуется с порядком, установленным методикой оценки угроз безопасности информации [34], в соответствии с которым угроза описывается совокупностью нарушителя, способа реализации, объекта воздействия и наступающих последствий. Отличие состоит в выборе объекта воздействия: методика относит к объектам воздействия компоненты информационной системы – программное обеспечение, средства вычислительной техники, каналы связи, – тогда как в настоящей работе объектом воздействия выступает актив кластера, а достигаемый ущерб определяется множеством активов, достижимых при компрометации исходной рабочей нагрузки. Такое уточнение перечня объектов воздействия применительно к конкретной информационной системе методикой допускается, однако требует самостоятельного определения характеризующих объект показателей, что выполняется в рамках дальнейшего исследования.

Существенной особенностью построенного дерева является то, что переход от угрозы к риску в нём обусловлен не наличием уязвимости, а состоянием конфигурации кластера. Так, риск Р1.1 реализуется лишь для тех рабочих нагрузок, которым разрешено исполнение в привилегированном режиме, а риск Р3.1 – лишь для тех, сервисный аккаунт которых располагает полномочиями, превышающими необходимые для решения прикладной задачи. Тем самым дерево угроз оказывается не универсальным описанием, а функцией от фактического состава рабочих нагрузок и предоставленных им полномочий, что и обусловливает необходимость

его пересчёта при каждом изменении конфигурации, реализуемого разрабатываемой интеллектуальной системой.

Построенное дерево применимо ко всем выделенным группам активов, однако состав реализуемых цепочек рисков для них различен. Для рабочих нагрузок, обслуживающих внешние обращения, характерны цепочки, начинающиеся с компрометации прикладного кода и продолжающиеся выходом за границы контейнера. Для нагрузок, располагающих полномочиями управления объектами кластера, определяющими являются цепочки, ведущие непосредственно к плоскости управления, минуя компрометацию узла. Для системных нагрузок, размещаемых на всех узлах кластера, характерна цепочка, в которой компрометация единственного экземпляра влечёт последствия для всей инфраструктуры. Данное различие подтверждает, что оценка риска должна выполняться применительно к конкретной рабочей нагрузке, а не к кластеру в целом, и обосновывает выбор рабочей нагрузки в качестве единицы риск-анализа.

1.8 Выводы по первому разделу

Выполненное в настоящем разделе исследование инфраструктуры контейнеризации Kubernetes как объекта защиты, информационного обеспечения риск-анализа контейнерных сред и существующих средств анализа защищённости позволило получить следующие результаты.

- построена модель инфраструктуры контейнеризации как объекта защиты, включающая четыре группы активов – плоскость управления, вычислительные узлы, рабочие нагрузки и реестр образов – и четыре границы доверия между ними; установлено, что величина ущерба от компрометации рабочей нагрузки определяется множеством активов, достижимых при её использовании, а не свойствами самой нагрузки;

- обосновано положение рабочей нагрузки в качестве начального, а не конечного звена цепочки компрометации, что позволяет включить в рассмотрение переходы между границами доверия, остающиеся вне поля зрения при пообъектной оценке защищённости;

- предложена классификация недостатков конфигурации кластера по активам объекта защиты, объединяющая пять групп – недостатки рабочих нагрузок, сервисных аккаунтов и привязок ролей, плоскости управления, вычислительных узлов и реестра образов – и обладающая свойством полноты относительно принятой модели объекта защиты;

- установлено, что международные реестры уязвимостей CVE и NVD, банк данных угроз безопасности информации ФСТЭК России и калькуляторы критичности CVSS и EPSS имеют своей областью определения дефект программного обеспечения и непосредственно неприменимы к недостаткам конфигурации кластера, вследствие чего множество недостатков должно формироваться по руководству NIST SP 800-190 и набору проверок CIS Kubernetes Benchmark, а способ их эксплуатации – по матрице MITRE ATT&CK for Containers;

- выполнен сравнительный анализ средств анализа защищённости контейнерных сред, показавший, что kube-bench, Kubescape, Trivy и Falco дают дискретную оценку соответствия профилю безопасности, оценивают объекты кластера изолированно, не присваивают количественной оценки недостаткам без идентификатора уязвимости и не предусматривают переоценки состояния при изменении конфигурации;

- построено дерево угрозы и индуцированных ею рисков инфраструктуры контейнеризации, системообразующим событием которого является компрометация контейнерного приложения, содержащее двенадцать рисков, разделённых на технические, информационные, экономические и правовые, и четыре частные угрозы по числу пересекаемых границ доверия и допускающее формальное описание, в котором путь от недостатка конфигурации к риску верхнего уровня образует сценарий компрометации.

- установлено соответствие между мерами защиты информации, предусмотренными приказами ФСТЭК России и национальными стандартами, и параметрами конфигурации кластера, посредством которых эти меры реализуются, чем определено множество контролируемых параметров объекта защиты;

Полученные результаты обосновывают постановку задач исследования. Установленная неприменимость реестров уязвимостей к недостаткам конфигурации кластера определяет необходимость формирования базы знаний соответствий недостатков конфигурации и эксплуатирующих их техник с привязкой каждой пары к наступающему ущербу. Отсутствие количественной оценки критичности у недостатков без идентификатора уязвимости определяет необходимость разработки методики количественной оценки вероятности успешной компрометации контейнерного приложения и величины наступающего ущерба. Пообъектный характер существующих проверок определяет необходимость формирования типовых сценариев компрометации в виде путей достижимости активов. Статичность действующих методик определяет необходимость создания интеллектуальной системы, выполняющей классификацию рабочих нагрузок по уровню риска и пересчёт риск-ландшафта при смене снимка конфигурации, а также выработки комплекса мер риск-регулирования, классифицированных по масштабности и профильности. Решение перечисленных задач составляет содержание последующих разделов выпускной квалификационной работы.

СПИСОК ЛИТЕРАТУРЫ

1 Kubernetes Documentation: официальная документация системы оркестрации контейнерных приложений. – Электрон. дан. – Режим доступа: https://kubernetes.io/docs/. – Текст: электронный.

2 State of Kubernetes Security Report: ежегодный аналитический отчёт компании Red Hat. – Электрон. дан. – Режим доступа: https://www.redhat.com/en/resources/state-kubernetes-security-report. – Текст: электронный.

3 Cloud-Native Security and Usage Report: ежегодный аналитический отчёт компании Sysdig. – Электрон. дан. – Режим доступа: https://sysdig.com/. – Текст: электронный.

4 CNCF Annual Survey: ежегодное исследование фонда Cloud Native Computing Foundation. – Электрон. дан. – Режим доступа: https://www.cncf.io/reports/. – Текст: электронный.

5 Data Breach Investigations Report: ежегодный аналитический отчёт компании Verizon. – Электрон. дан. – Режим доступа: https://www.verizon.com/business/resources/reports/dbir/. – Текст: электронный.

6 Утечки данных в России и мире: аналитический отчёт экспертно-аналитического центра InfoWatch. – Электрон. дан. – Режим доступа: https://www.infowatch.ru/analytics. – Текст: электронный.

7 Актуальные киберугрозы: аналитические отчёты компании Positive Technologies. – Электрон. дан. – Режим доступа: https://www.ptsecurity.com/ru-ru/research/analytics/. – Текст: электронный.

8 Банк данных угроз безопасности информации ФСТЭК России. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/threat. – Текст: электронный.

9 Common Vulnerabilities and Exposures (CVE). – Электрон. дан. – Режим доступа: https://www.cve.org/. – Текст: электронный.

10 National Vulnerability Database (NVD). – Электрон. дан. – Режим доступа: https://nvd.nist.gov/. – Текст: электронный.

11 Common Vulnerability Scoring System v3.1: Specification Document. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v3.1/specification-document. – Текст: электронный.

12 Common Vulnerability Scoring System v4.0: Specification Document. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v4.0/specification-document. – Текст: электронный.

13 Exploit Prediction Scoring System (EPSS). – Электрон. дан. – Режим доступа: https://www.first.org/epss/. – Текст: электронный.

14 Kubescape: средство анализа защищённости кластера Kubernetes. – Электрон. дан. – Режим доступа: https://github.com/kubescape/kubescape. – Текст: электронный.

15 kube-bench: средство проверки конфигурации кластера на соответствие CIS Kubernetes Benchmark. – Электрон. дан. – Режим доступа: https://github.com/aquasecurity/kube-bench. – Текст: электронный.

16 Trivy: средство выявления уязвимостей образов контейнеров и ошибок конфигурации. – Электрон. дан. – Режим доступа: https://github.com/aquasecurity/trivy. – Текст: электронный.

17 Falco: средство обнаружения аномального поведения среды исполнения контейнеров. – Электрон. дан. – Режим доступа: https://falco.org/docs/. – Текст: электронный.

18 Остапенко А.Г. Краткие научно-методические рекомендации по формированию и выполнению технических заданий в области обеспечения информационной безопасности / А.Г. Остапенко, М.Е. Волкова, Д.А. Нархов, А.А. Остапенко, А.В. Заряев, Т.Ю. Мирошниченко, П.Д. Федоров // Информация и безопасность. – 2020. – Т. 23, вып. 4. – С. 551-560. – Текст: непосредственный.

19 Остапенко Г.А. Совершенствование организационно-правового обеспечения информационной безопасности предприятия: формирование риск-ландшафта сетевых атак / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Ю. Пекло // Информация и безопасность. – 2023. – Т. 26, вып. 2. – С. 203-210. – Текст: непосредственный.

20 Сердечный А.Л. Риск-анализ и прогнозирование частоты и ущербности компьютерных атак / А.Л. Сердечный, А.С. Маликова, А.Г. Остапенко, М.Е. Волкова, Д.А. Нархов, А.Н. Бартенев // Информация и безопасность. – 2021. – Т. 24, вып. 2. – С. 159-178. – Текст: непосредственный.

21 Об утверждении Требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах: приказ ФСТЭК России от 11 февраля 2013 г. № 17. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/prikazy/prikaz-fstek-rossii-ot-11-fevralya-2013-g-n-17. – Текст: электронный.

22 Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных: приказ ФСТЭК России от 18 февраля 2013 г. № 21. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/prikazy/prikaz-fstek-rossii-ot-18-fevralya-2013-g-n-21. – Текст: электронный.

23 Об утверждении Требований по обеспечению безопасности значимых объектов критической информационной инфраструктуры Российской Федерации: приказ ФСТЭК России от 25 декабря 2017 г. № 239. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/prikazy/prikaz-fstek-rossii-ot-25-dekabrya-2017-g-n-239. – Текст: электронный.

24 ГОСТ Р 50922-2006. Защита информации. Основные термины и определения. – Москва: Стандартинформ, 2006. – Текст: непосредственный.

25 ГОСТ Р 56545-2015. Защита информации. Уязвимости информационных систем. Правила описания уязвимостей. – Москва: Стандартинформ, 2015. – Текст: непосредственный.

26 ГОСТ Р 56546-2015. Защита информации. Уязвимости информационных систем. Классификация уязвимостей информационных систем. – Москва: Стандартинформ, 2015. – Текст: непосредственный.

27 NIST Special Publication 800-190. Application Container Security Guide. – Электрон. дан. – Режим доступа: https://csrc.nist.gov/publications/detail/sp/800-190/final. – Текст: электронный.

28 CIS Kubernetes Benchmark: набор проверок конфигурации кластера центра интернет-безопасности. – Электрон. дан. – Режим доступа: https://www.cisecurity.org/benchmark/kubernetes. – Текст: электронный.

29 MITRE ATT&CK Containers Matrix. – Электрон. дан. – Режим доступа: https://attack.mitre.org/matrices/enterprise/containers/. – Текст: электронный.

30 Sultan S. Container Security: Issues, Challenges, and the Road Ahead / S. Sultan, I. Ahmad, T. Dimitriou // IEEE Access. – 2019. – Vol. 7. – P. 52976-52996. – Текст: непосредственный.

31 etcd: распределённое хранилище состояния кластера. – Электрон. дан. – Режим доступа: https://etcd.io/docs/. – Текст: электронный.

32 containerd: среда исполнения контейнеров. – Электрон. дан. – Режим доступа: https://containerd.io/docs/. – Текст: электронный.

33 Using RBAC Authorization: механизм управления доступом на основе ролей в Kubernetes. – Электрон. дан. – Режим доступа: https://kubernetes.io/docs/reference/access-authn-authz/rbac/. – Текст: электронный.

34 Методика оценки угроз безопасности информации: методический документ ФСТЭК России, утверждён 5 февраля 2021 г. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/spetsialnye-normativnye-dokumenty/metodicheskij-dokument-ot-5-fevralya-2021-g. – Текст: электронный.

35 ГОСТ Р 56938-2016. Защита информации. Защита информации при использовании технологий виртуализации. Общие положения. – Москва: Стандартинформ, 2016. – Текст: непосредственный.

36 ГОСТ Р ИСО/МЭК 27005-2010. Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности. – Москва: Стандартинформ, 2011. – Текст: непосредственный.

37 ГОСТ Р 58771-2019. Менеджмент риска. Технологии оценки риска. – Москва: Стандартинформ, 2020. – Текст: непосредственный.

38 Pod Security Standards: стандарты безопасности рабочих нагрузок Kubernetes. – Электрон. дан. – Режим доступа: https://kubernetes.io/docs/concepts/security/pod-security-standards/. – Текст: электронный.

39 Admission Controllers Reference: контроллеры допуска рабочих нагрузок в Kubernetes. – Электрон. дан. – Режим доступа: https://kubernetes.io/docs/reference/access-authn-authz/admission-controllers/. – Текст: электронный.

40 Rahman A. Security Misconfigurations in Open Source Kubernetes Manifests: An Empirical Study / A. Rahman, S.I. Shamim, D.B. Bose, R. Pandita // ACM Transactions on Software Engineering and Methodology. – 2023. – Vol. 32, № 4. – P. 1-36. – Текст: непосредственный.

41 Common Weakness Enumeration (CWE). – Электрон. дан. – Режим доступа: https://cwe.mitre.org/. – Текст: электронный.

42 CIS Docker Benchmark: набор проверок конфигурации среды исполнения контейнеров. – Электрон. дан. – Режим доступа: https://www.cisecurity.org/benchmark/docker. – Текст: электронный.

43 Kubernetes Hardening Guide: руководство Агентства национальной безопасности и Агентства по кибербезопасности и защите инфраструктуры США. – Электрон. дан. – Режим доступа: https://www.cisa.gov/resources-tools/resources/kubernetes-hardening-guide. – Текст: электронный.

44 OWASP Kubernetes Top Ten: перечень наиболее значимых рисков безопасности инфраструктуры Kubernetes. – Электрон. дан. – Режим доступа: https://owasp.org/www-project-kubernetes-top-ten/. – Текст: электронный.

45 Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин // Информация и безопасность. – 2024. – Т. 27, вып. 2. – С. 231-238. – Текст: непосредственный.

46 Sheyner O. Automated Generation and Analysis of Attack Graphs / O. Sheyner, J. Haines, S. Jha, R. Lippmann, J.M. Wing // Proceedings of the IEEE Symposium on Security and Privacy. – Oakland, 2002. – P. 273-284. – Текст: непосредственный.

47 Ou X. MulVAL: A Logic-based Network Security Analyzer / X. Ou, S. Govindavajhala, A.W. Appel // Proceedings of the 14th USENIX Security Symposium. – Baltimore, 2005. – P. 113-128. – Текст: непосредственный.

48 Poolsappasit N. Dynamic Security Risk Management Using Bayesian Attack Graphs / N. Poolsappasit, R. Dewri, I. Ray // IEEE Transactions on Dependable and Secure Computing. – 2012. – Vol. 9, № 1. – P. 61-74. – Текст: непосредственный.